

ICMP: Internet Control Message Protocol



ping

- ❑ ping *indirizzo IP oppure nome* ≡
"Caro *indirizzo IP oppure nome* confermami che ci sei"
- ❑ Comando disponibile in ogni sistema operativo
- ❑ Utile per troubleshooting

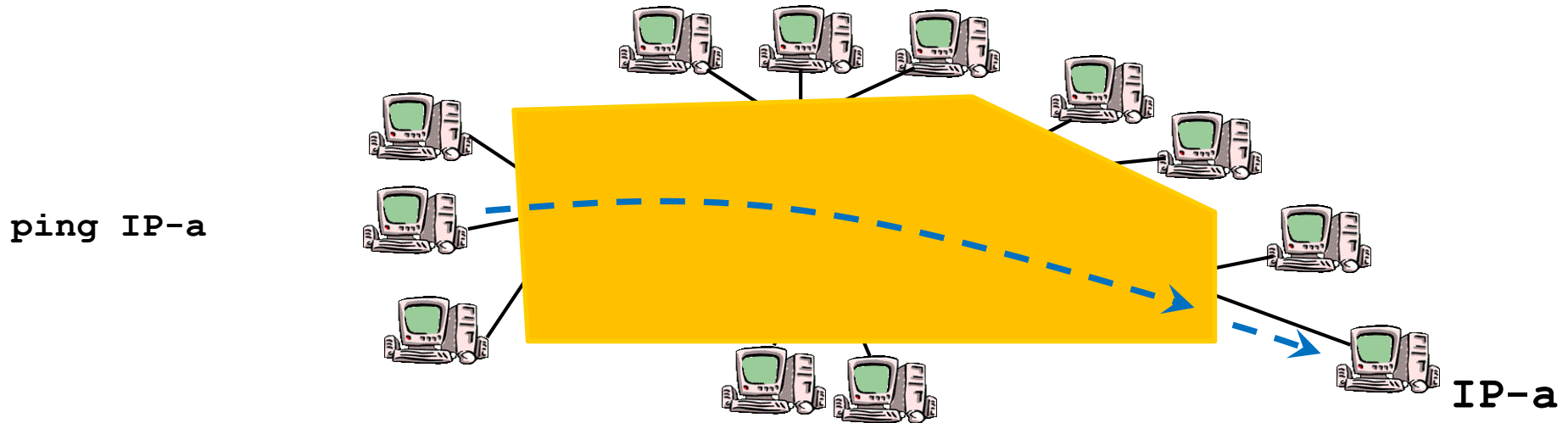
```
C:\Users\Alberto\Desktop>ping www.units.it

Esecuzione di Ping units09.cineca.it [130.186.9.36] con 32 byte di dati:
Risposta da 130.186.9.36: byte=32 durata=10ms TTL=54
Risposta da 130.186.9.36: byte=32 durata=10ms TTL=54
Risposta da 130.186.9.36: byte=32 durata=10ms TTL=54
Risposta da 130.186.9.36: byte=32 durata=9ms TTL=54

Statistiche Ping per 130.186.9.36:
    Pacchetti: Trasmessi = 4, Ricevuti = 4,
    Persi = 0 (0% persi),
Tempo approssimativo percorsi andata/ritorno in millisecondi:
    Minimo = 9ms, Massimo = 10ms, Medio = 9ms

C:\Users\Alberto\Desktop>
```

Come funziona ?



Ci deve essere un server in ascolto?
Su quale porta?



traceroute

- ❑ traceroute *indirizzo IP oppure nome*
 - ❑ Produce **elenco dei router** tra nodo che esegue il comando *indirizzo IP oppure nome*
 - ❑ Comando disponibile in ogni sistema operativo
- ❑ Utile per troubleshooting

```
C:\Users\Alberto\Desktop>tracert www.units.it

Traccia instradamento verso units09.cineca.it [130.186.9.36]
su un massimo di 30 punti di passaggio:

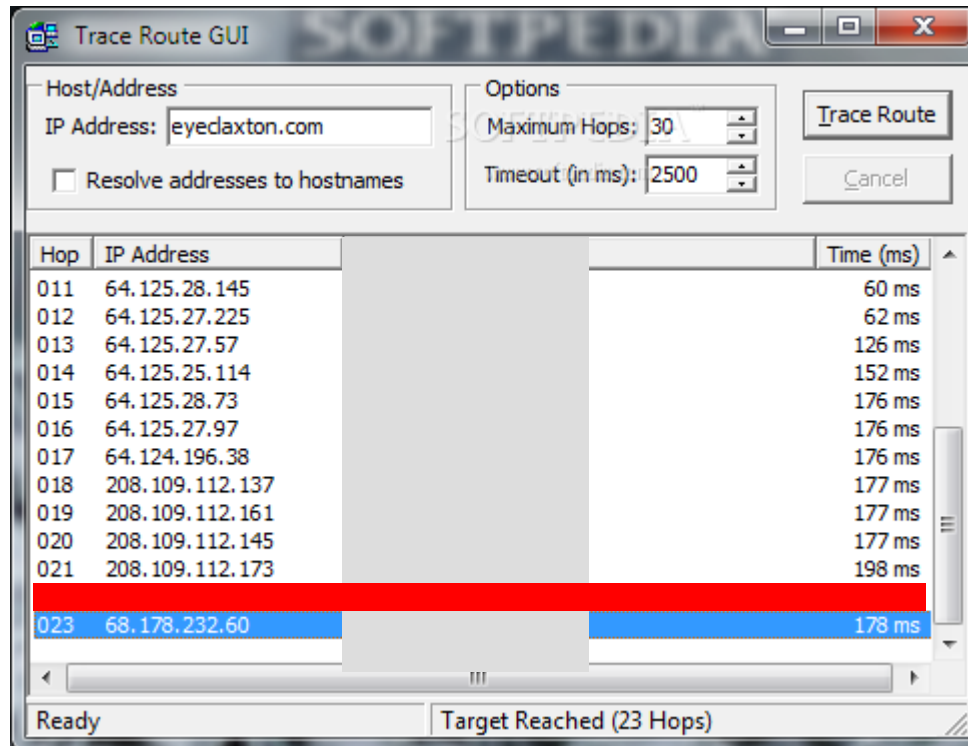
 1    <1 ms    <1 ms    <1 ms    140.105.50.254
 2     1 ms     1 ms     1 ms    rtcore.units.it [140.105.150.136]
 3    <1 ms    <1 ms    <1 ms    forti-core.units.it [140.105.150.89]
 4     1 ms     1 ms     1 ms    bg-forti.units.it [140.105.150.81]
 5    <1 ms    <1 ms    <1 ms    ru-units-rx1-ts1.ts1.garr.net [193.206.132.25]
 6     6 ms     6 ms     7 ms    rx1-ts1-rx2-mil.mil.garr.net [90.147.82.173]
 7     9 ms     9 ms     9 ms    rx2-mil-rx2-bo1.bo1.garr.net [90.147.80.6]
 8    10 ms    10 ms     9 ms    rx1-bo1-ru-cineca-bo-11.bo1.garr.net [193.206.128.138]
 9     9 ms     9 ms     9 ms    c03-v1113.cineca.net [130.186.22.18]
10    10 ms    10 ms    10 ms    dl1-v1231.cineca.net [130.186.22.10]
11     9 ms     9 ms     9 ms    units09.cineca.it [130.186.9.36]

Traccia completata.

C:\Users\Alberto\Desktop>
```

traceroute:

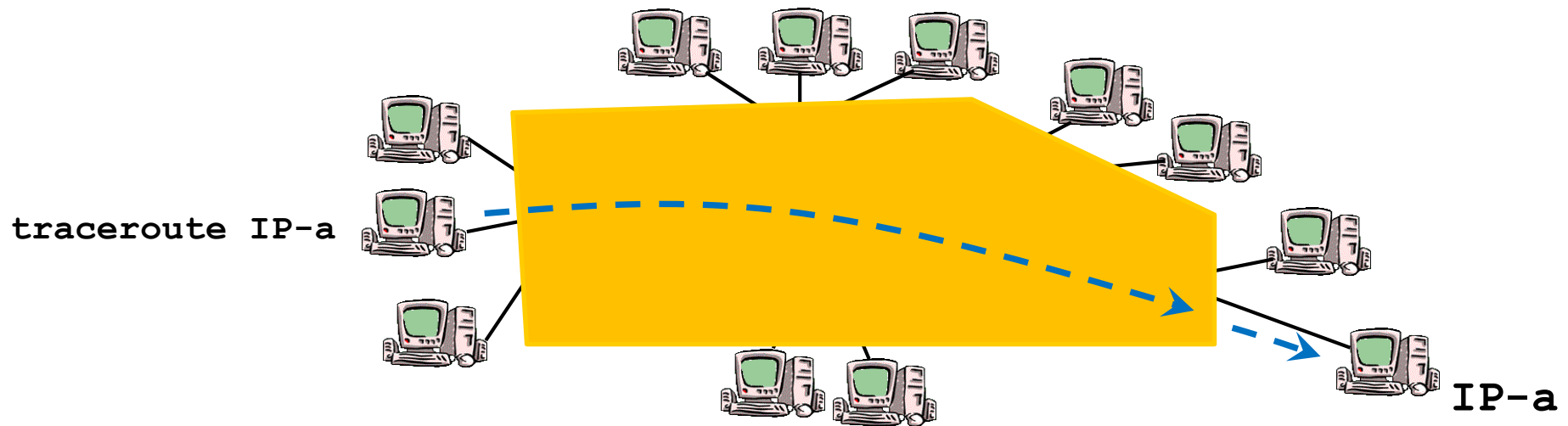
Altra interfaccia



The screenshot shows the 'Trace Route GUI' window. The 'Host/Address' field contains 'eyedaxton.com'. The 'Options' section shows 'Maximum Hops' set to 30 and 'Timeout (in ms)' set to 2500. The 'Trace Route' button is highlighted. Below the input fields is a table showing the results of the traceroute. The table has three columns: 'Hop', 'IP Address', and 'Time (ms)'. The results show a path of 23 hops, with the final hop (23) highlighted in blue and the entire row highlighted in red. The status bar at the bottom indicates 'Ready' and 'Target Reached (23 Hops)'.

Hop	IP Address	Time (ms)
011	64.125.28.145	60 ms
012	64.125.27.225	62 ms
013	64.125.27.57	126 ms
014	64.125.25.114	152 ms
015	64.125.28.73	176 ms
016	64.125.27.97	176 ms
017	64.124.196.38	176 ms
018	208.109.112.137	177 ms
019	208.109.112.161	177 ms
020	208.109.112.145	177 ms
021	208.109.112.173	198 ms
023	68.178.232.60	178 ms

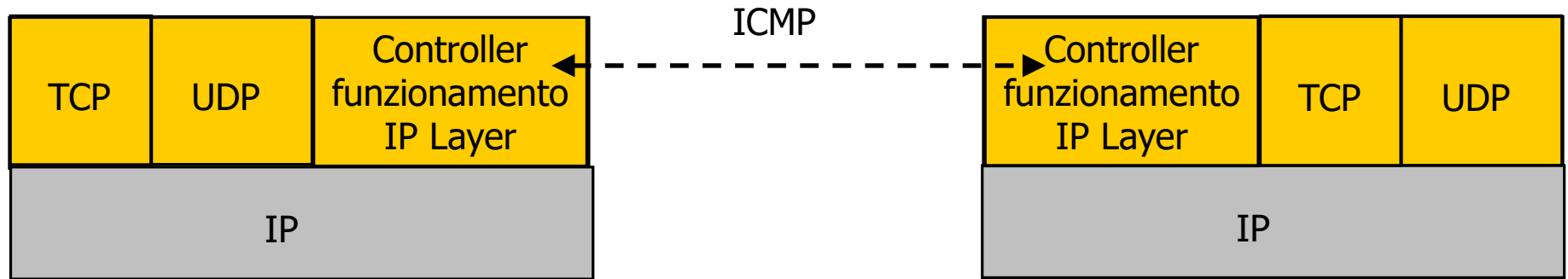
Come funziona ?



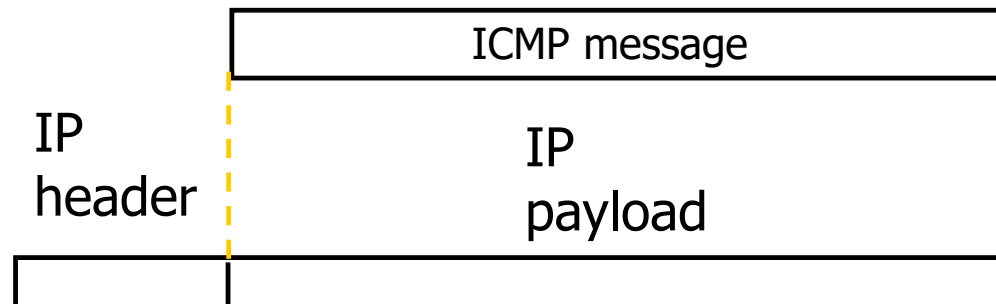
Come faccio a scoprire il cammino?
E se il cammino cambia?



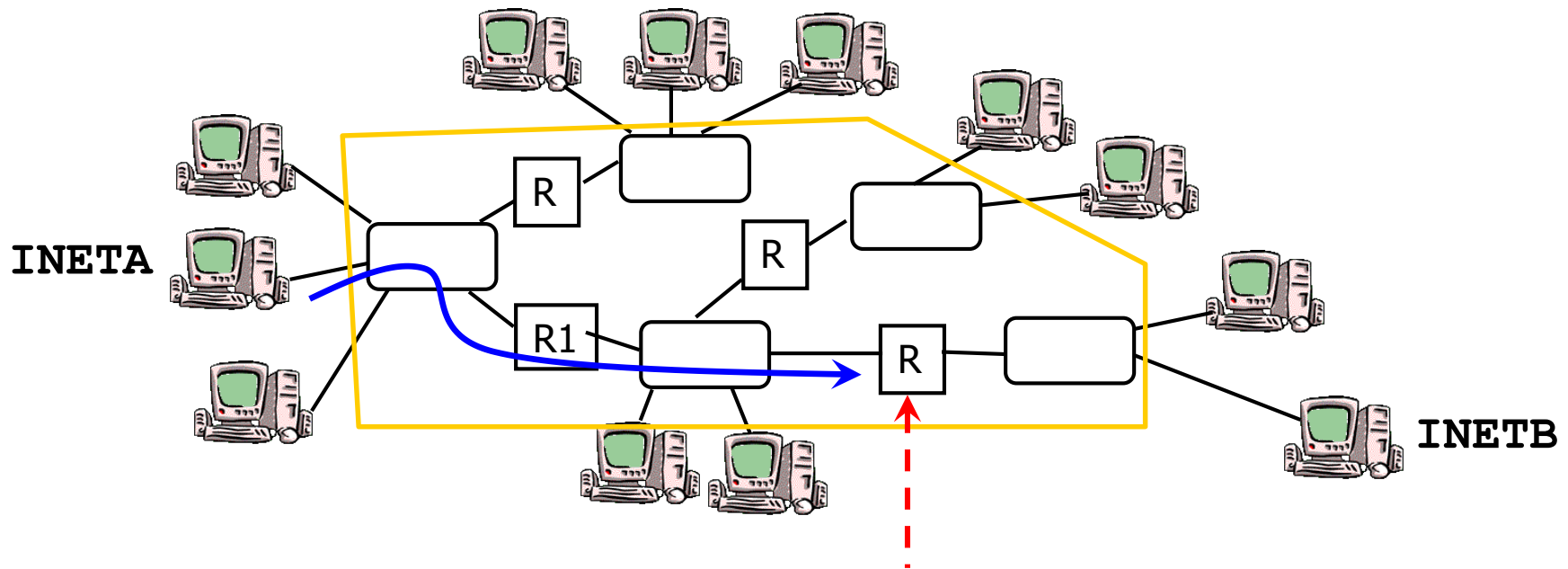
ICMP (I)



- Protocollo per lo scambio di “informazioni sul funzionamento” del livello IP

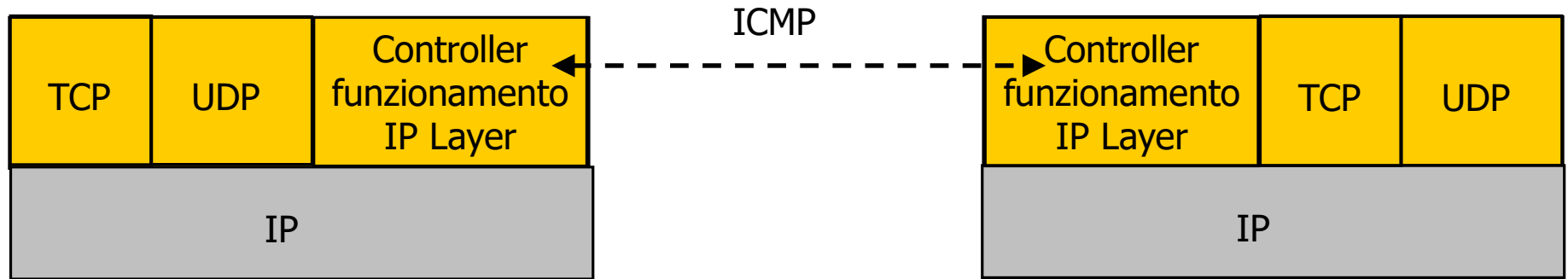


Utilizzo tipico: "non può proseguire"



- Se il pacchetto non può proseguire, invia un messaggio ICMP a **INETA**
- NB: **non** ad **R1**

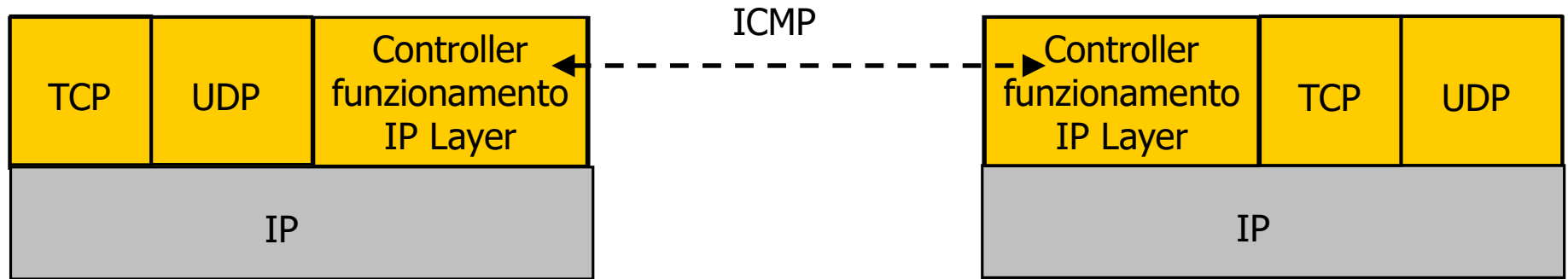
ICMP (II)



Tipico: notifica **situazioni anomale**

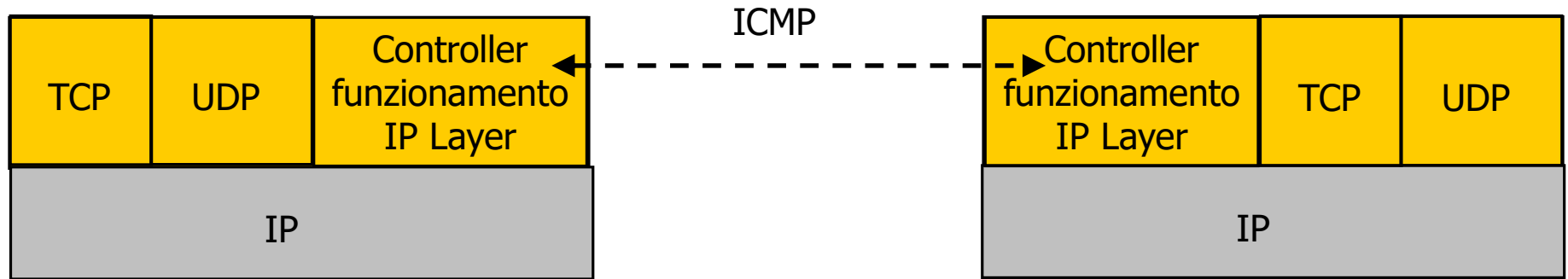
- ☐ Destinatario irraggiungibile
- ☐ TTL scaduto
- ☐ Header IP errato
- ☐ ...

ICMP (III)



- ❑ Messaggi ICMP possono:
 - ❑ Essere persi
 - ❑ Essere duplicati
 - ❑ Arrivare fuori ordine
- ❑ Ovvio: trasportati da IP

Utilizzo tipico: ping (I)



Tipico: notifica **situazioni anomale**

- ...

Anche:

- Echo request

“Dimmi se ci sei”

- Echo reply

“Ci sono”

- ...

- Posso "pingare" qualunque nodo che esegue ICMP

- Anche i router

Utilizzo tipico: ping (II)

ping IP-a

- Invio ad IP-a di ICMP message "echo request"

IP-snd IP-a ICMP	echo request
------------------	--------------

- SE IP-a implementa ICMP
ALLORA risponde con ICMP message "echo reply"

IP-a IP-snd ICMP	echo reply
------------------	------------

Bocciatura automatica

Una delle numerose fantasiose varianti:



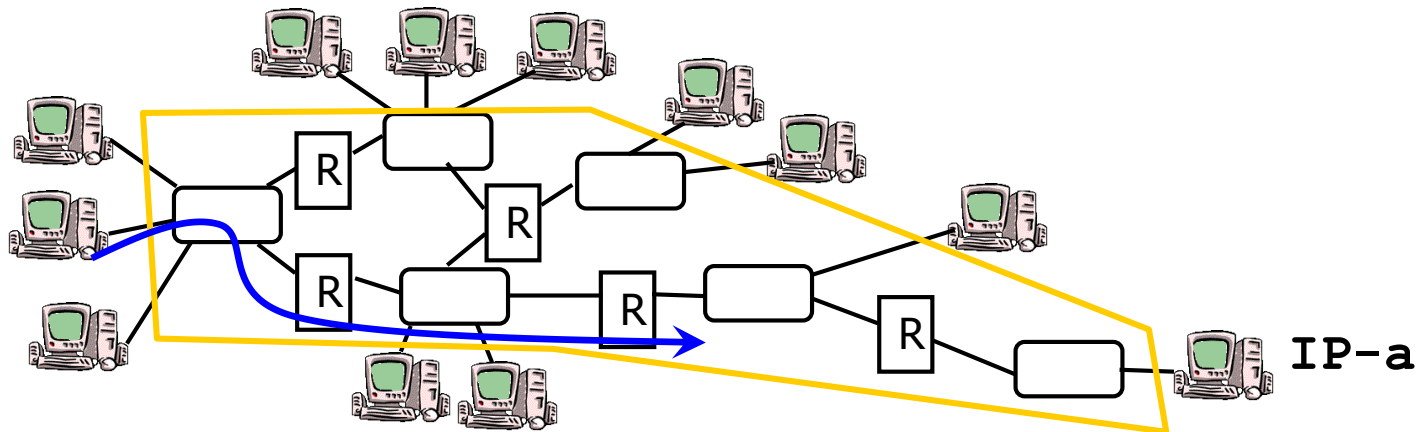
(frame Ethernet)

Il messaggio ICMP deve arrivare ad un destinatario **in un'altra network**
Come caspita fa ad arrivare se non è incapsulato in un pacchetto IP?

Traceroute: Implementazione

traceroute IP-a

- Invio a IP-a ICMP "echo request" con **TTL = 1**
⇒ il **primo** router risponde con ICMP type = "TTL expired"
- Invio a IP-a ICMP "echo request" con **TTL = 2**
⇒ il **secondo** router risponde ICMP type = "TTL expired"
- ...



Esempio (I)

No. .	Time	Source	Destination	Protocol	Info
1	0.000000	157.59.11.19	157.54.224.33	ICMP	Echo (ping) request
2	0.000000	157.59.8.1	157.59.11.19	ICMP	Time-to-live exceeded
7	1.022000	157.59.11.19	157.54.224.33	ICMP	Echo (ping) request
8	1.022000	157.54.231.130	157.59.11.19	ICMP	Time-to-live exceeded
13	2.023000	157.59.11.19	157.54.224.33	ICMP	Echo (ping) request
14	2.024000	157.54.224.33	157.59.11.19	ICMP	Echo (ping) reply

Primo router

157.59.8.1

Secondo router

157.54.231.130

Destinazione

157.54.224.33

[x] Frame 7 (106 on wire, 106 captured)
 [x] Ethernet II
 [x] Internet Protocol, Src Addr: 157.59.11.19 (157.59.11.19), Dst Addr: 157.54.224.33 (157.54.224.33)
 Version: 4
 Header length: 20 bytes
 [x] Differentiated Services Field: 0x00 (DSCP 0x00: Default; ECN: 0x00)
 Total Length: 92
 Identification: 0x324b
 [x] Flags: 0x00
 Fragment offset: 0
 Time to live: 2
 Protocol: ICMP (0x01)
 Header checksum: 0x60b0 (correct)
 Source: 157.59.11.19 (157.59.11.19)
 Destination: 157.54.224.33 (157.54.224.33)
 [x] Internet Control Message Protocol

Esempio (II)

No. .	Time	Source	Destination	Protocol	Info
1	0.000000	157.59.11.19	157.54.224.33	ICMP	Echo (ping) request
2	0.000000	157.59.8.1	157.59.11.19	ICMP	Time-to-live exceeded
3	0.001000	157.59.11.19	157.54.224.33	ICMP	Echo (ping) request
4	0.001000	157.59.8.1	157.59.11.19	ICMP	Time-to-live exceeded
5	0.019000	157.59.11.19	157.54.224.33	ICMP	Echo (ping) request
6	0.019000	157.59.8.1	157.59.11.19	ICMP	Time-to-live exceeded
7	1.022000	157.59.11.19	157.54.224.33	ICMP	Echo (ping) request
8	1.022000	157.54.231.130	157.59.11.19	ICMP	Time-to-live exceeded
9	1.023000	157.59.11.19	157.54.224.33	ICMP	Echo (ping) request
10	1.024000	157.54.231.130	157.59.11.19	ICMP	Time-to-live exceeded
11	1.024000	157.59.11.19	157.54.224.33	ICMP	Echo (ping) request
12	1.025000	157.54.231.130	157.59.11.19	ICMP	Time-to-live exceeded
13	2.023000	157.59.11.19	157.54.224.33	ICMP	Echo (ping) request
14	2.024000	157.54.224.33	157.59.11.19	ICMP	Echo (ping) reply
15	2.025000	157.59.11.19	157.54.224.33	ICMP	Echo (ping) request
16	2.026000	157.54.224.33	157.59.11.19	ICMP	Echo (ping) reply
17	2.027000	157.59.11.19	157.54.224.33	ICMP	Echo (ping) request
18	2.027000	157.54.224.33	157.59.11.19	ICMP	Echo (ping) reply
19	-1.241000	XEROX_00:00:00	XEROX_00:00:00	0x1984	Netmon Train

⊞ Frame 7 (106 on wire, 106 captured)

⊞ Ethernet II

⊞ Internet Protocol, Src Addr: 157.59.11.19 (157.59.11.19), Dst Addr: 157.54.224.33 (157.54.224.33)

Version: 4

Header length: 20 bytes

⊞ Differentiated Services Field: 0x00 (DSCP 0x00: Default; ECN: 0x00)

Total Length: 92

Identification: 0x324b

⊞ Flags: 0x00

Fragment offset: 0

Time to live: 2

Protocol: ICMP (0x01)

Header checksum: 0x60b0 (correct)

Source: 157.59.11.19 (157.59.11.19)

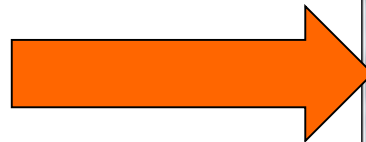
Destination: 157.54.224.33 (157.54.224.33)

⊞ Internet Control Message Protocol

*3 ritrasmissioni a ogni hop,
per mascherare eventuali perdite*

Traceroute: Osservazioni

- ❑ Le route possono variare nel tempo
 - ❑ Ma l'evento di variazione è "poco frequente"
- ❑ Un router non è obbligato a inviare notifiche ICMP
 - ❑ Fornire informazioni a sconosciuti non è mai una buona idea



Trace Route GUI

Host/Address
IP Address:

☐ Resolve addresses to hostnames

Options
Maximum Hops:
Timeout (in ms):

Hop	IP Address	Time (ms)
011	64.125.28.145	60 ms
012	64.125.27.225	62 ms
013	64.125.27.57	126 ms
014	64.125.25.114	152 ms
015	64.125.28.73	176 ms
016	64.125.27.97	176 ms
017	64.124.196.38	176 ms
018	208.109.112.137	177 ms
019	208.109.112.161	177 ms
020	208.109.112.145	177 ms
021	208.109.112.173	198 ms
022	0.0.0.0	0 ms
023	68.178.232.60	178 ms

Ready Target Reached (23 Hops)

Google Colab Notebook



Internetwork

ICMP

Firewall: Necessità



Premessa 1 (I)

- ❑ **SQL Slammer** is a 2003 computer worm that caused a denial of service on some Internet hosts and **dramatically slowed general Internet traffic**.
- ❑ It spread rapidly, infecting most of its **75,000 victims within ten minutes**.
- ❑ The program exploited a **Remote Code Execution vulnerability** in **Microsoft's SQL Server** and **Desktop Engine** database products.

Vulnerability = (A certain kind of) software **mistake**

Remote Code Execution vulnerability:

- ❑ Find server S with vulnerability V
- ❑ Connect(IP-S, port-SQLServer)
- ❑ Send message m(P) that "exploits V" → **Install program P on S**

Premessa 1 (II)



Malware P:

- ❑ foreach ip-X **on the Internet**
 - ❑ connect(ip-X, port-SQLServer)
 - ❑ IF connected THEN send message $m(P)$ → Install program P
- 1. Attacker writes P that exploits vulnerability V
- 2. P **automatically** propagates itself on **all** Internet nodes with V
- 3. Attacker has installed a software of his choice on all such nodes

Premessa 1 (III)



- ❑ **SQL Slammer** is a 2003 computer worm that caused a denial of service on some Internet hosts and **dramatically slowed general Internet traffic**.
- ❑ It spread rapidly, infecting most of its **75,000 victims within ten minutes**.
- ❑ The program exploited a Remote Code Execution vulnerability in **Microsoft's SQL Server** and **Desktop Engine** database products.
- ❑ Organizzazione Org-X ha server vulnerabili accessibili da qualunque parte del mondo
- ❑ E' necessario che siano accessibili **da qualunque parte del mondo?**
- ❑ Sa di **averli?**

Esempio 1 (di migliaia...)

- ❑ **WannaCry** was a worldwide cyberattack in May 2017
- ❑ The attack was estimated to have infected more than 200,000 computers across 150 countries in less than 12 hours, with total damages ranging from hundreds of millions to billions of dollars
- ❑ The code is capable of targeting vulnerable machine by IP address and attempting exploitation via SMB port 445

- ❑ Altro punto di vista:
 - ❑ Organizzazione O-X ha N server SMB accessibili da tutto il mondo

 - ❑ E' necessario che siano accessibili **da qualunque parte del mondo?**
 - ❑ Sa di **averli?**

Esempio 2 (di migliaia...)



HP patches wormable bug impacting more than 150 multi-functional printers

Catalin Cimpanu

November 30, 2021

The **Record.**
BY RECORDED FUTURE

- ❑ The vulnerability can be used to create wormable exploits that can self-replicate and spread to other HP printers inside internal networks or over the internet

Esempio 3 (di migliaia...)



HMI SCADA Automation Software for
32-bit Systems



CYBERSECURITY
& INFRASTRUCTURE
SECURITY AGENCY



ICS Advisory (ICSA-20-170-03)

ICONICS GENESIS64, GENESIS32

Original release date: June 18, 2020

- ❑ **Vulnerabilities:** Out-of-Bounds Write, Deserialization of Untrusted Data, Code Injection
- ❑ Successful exploitation of these vulnerabilities may allow remote code execution or denial of service.

Conseguenza in parole povere



- ❑ Nessuna organizzazione può più permettere:
 - ❑ "ogni tipologia di traffico" tra nodi interni e nodi esterni
 - ❑ "ogni tipologia di traffico" tra un nodo interno e gli altri nodi (interni o esterni)

- ❑ Ogni tipologia di traffico permesso è un **rischio potenziale**

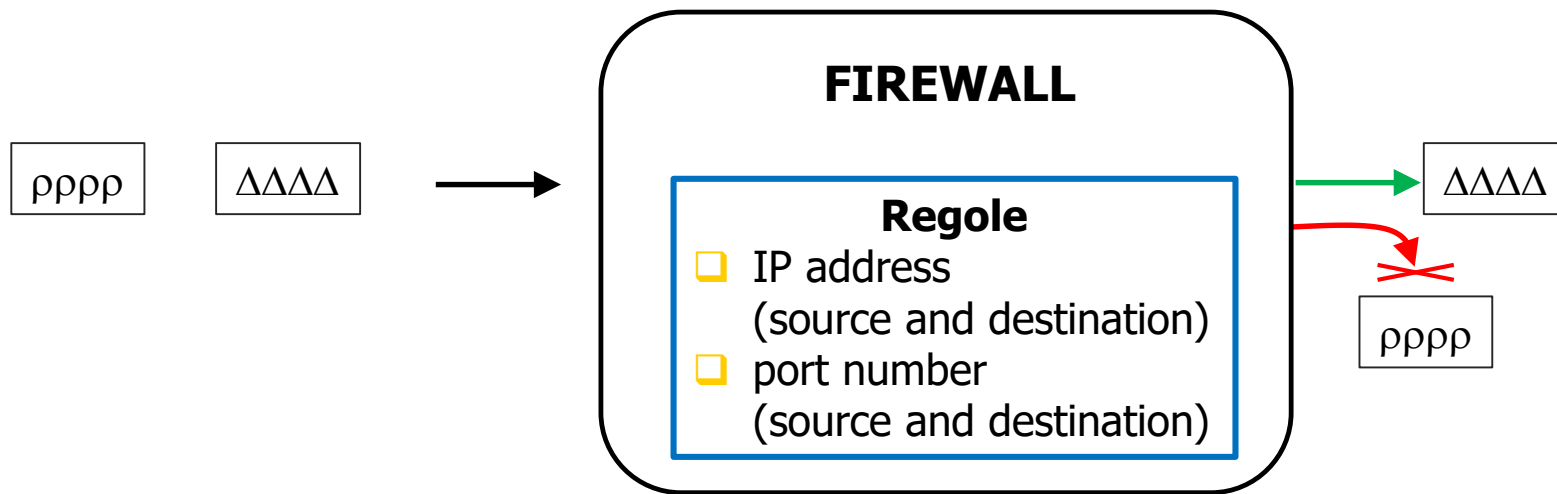
- ❑ Idealmente, bisognerebbe permettere **solo** il traffico **strettamente necessario**

Firewall

A horizontal yellow brushstroke with a textured, painterly appearance, extending across the width of the slide below the title.

Firewall (I)

- ❑ Dispositivo software che:
 - ❑ **Analizza traffico** entrante/uscente
 - ❑ Filtra traffico da **permettere** o da **bloccare**
 - ❑ Algoritmo di filtraggio basato su **regole** configurabili



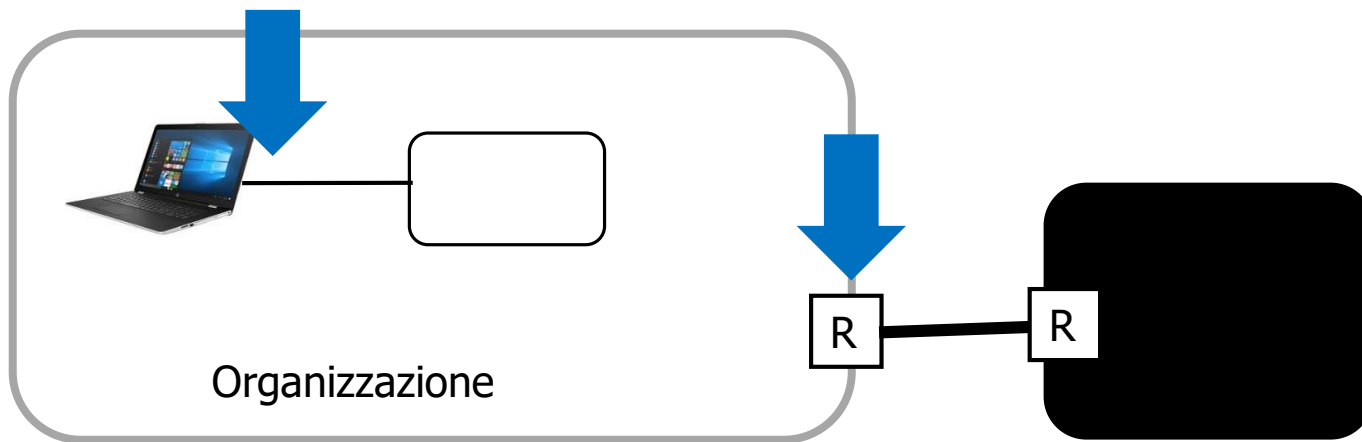
Firewall (II)

- Algoritmo di filtraggio basato su **regole** configurabili
 - regola = BooleanFunction(**IP-src, IP-dst, port-src, port-dst**)
 - operatori disponibili: AND, OR, NOT, "in intervallo", ...
- Algoritmo:

```
IF      regola1 THEN  passa
ELSEIF  regola2 THEN  passa
ELSEIF  regola3 THEN  passa
...
ELSE    scarta
```
- **"Tutto proibito"** (a meno che non sia permesso **esplicitamente**)

Dove si trova (I)

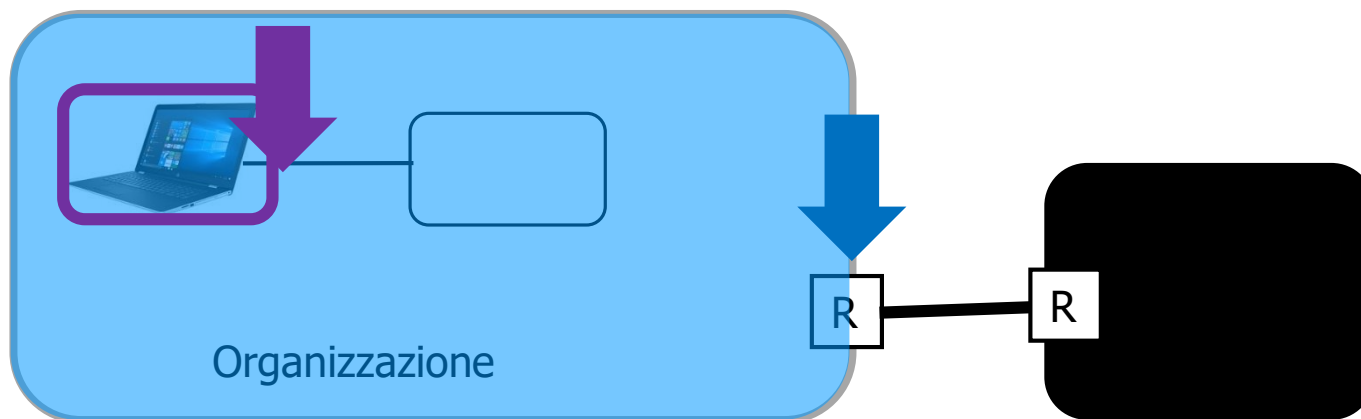
- ❑ Localizzato su:
 - ❑ Router di frontiera
 - ❑ Dispositivi personali



Talvolta la parola "firewall" ha la stessa ambiguità di "server": software o hardware?

Dove si trova (II)

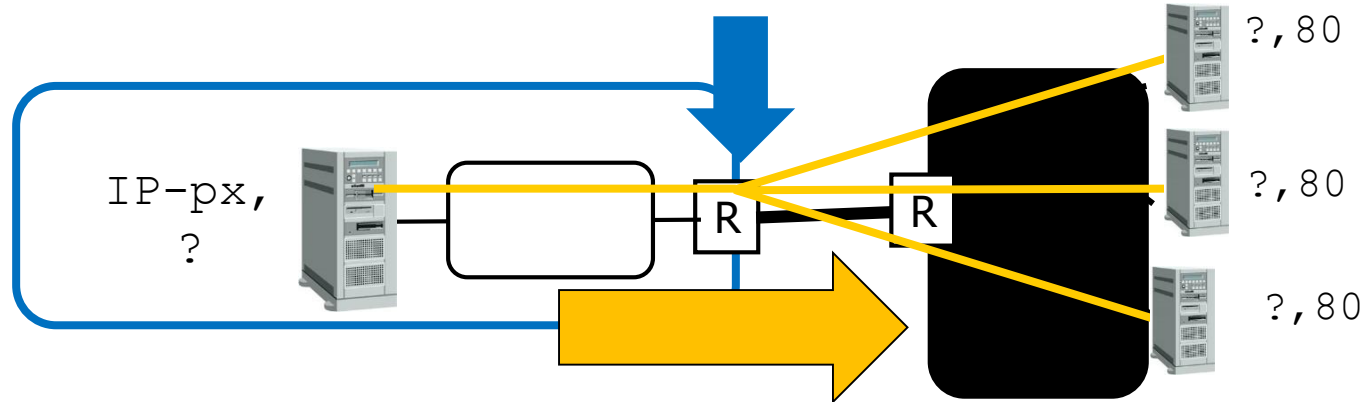
- ❑ In parole povere: protegge "ambiente **interno**"
 - ❑ Router di frontiera: ambiente interno $\equiv$ organizzazione
 - ❑ Dispositivi personali: ambiente interno $\equiv$ dispositivo su cui è il firewall



- ❑ Praticamente **indispensabile**

Esempio:

Solo proxy naviga su web (I)

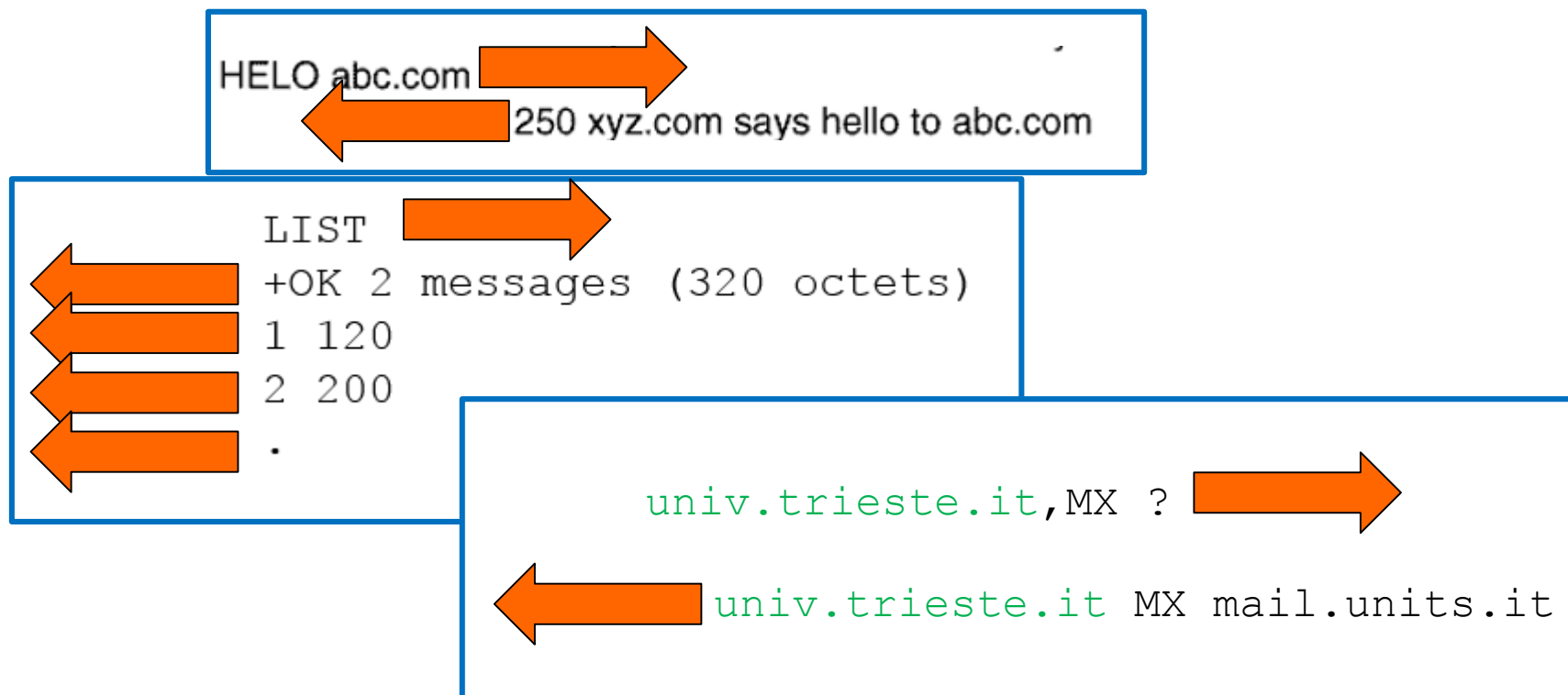


❑ Pacchetti **uscenti** permessi

- ❑ `IP-src = IP-proxy AND port-dst = 80`
- ❑ Ogni altro pacchetto uscente è proibito di default

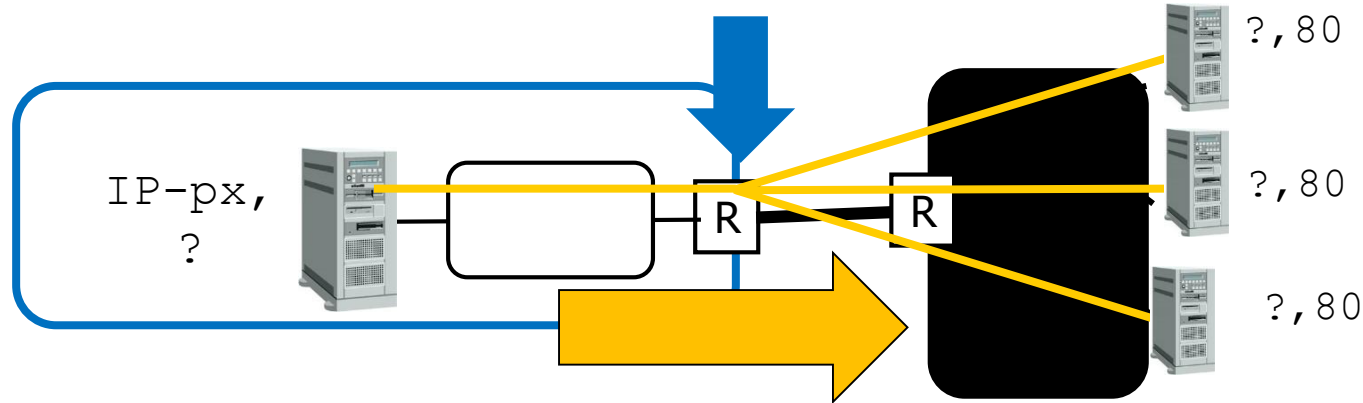
Importantissimo

Le connessioni TCP sono bidirezionali



Esempio:

Solo proxy naviga su web (II-a)



❑ Pacchetti **uscenti** permessi

❑ $IP\text{-}src = IP\text{-}proxy \text{ AND } port\text{-}dst = 80$

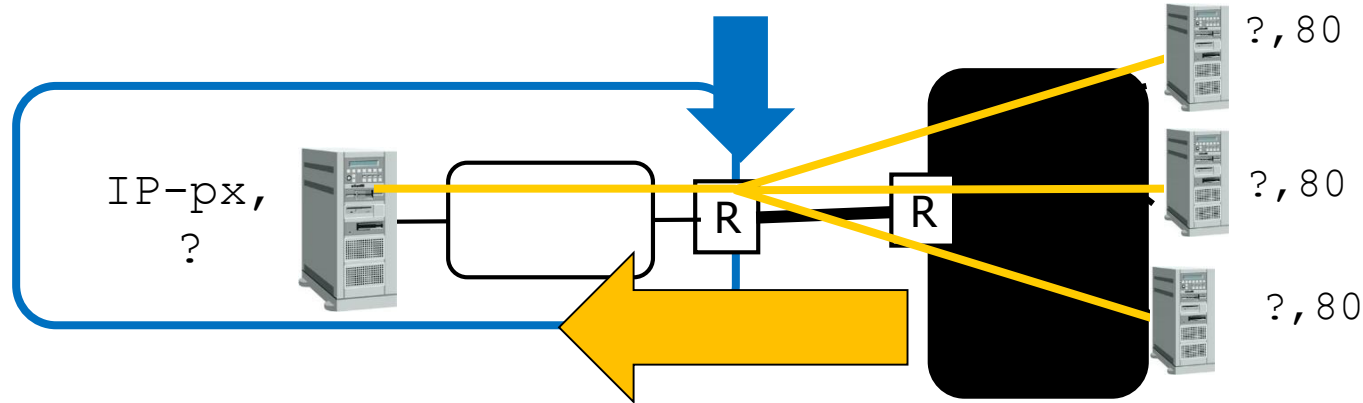
❑ Ogni altro pacchetto uscente è proibito di default

❑ Se permettessimo il passaggio **solo** a questi pacchetti

❑ Allora **non** funzionerebbe

Esempio:

Solo proxy naviga su web (II-b)



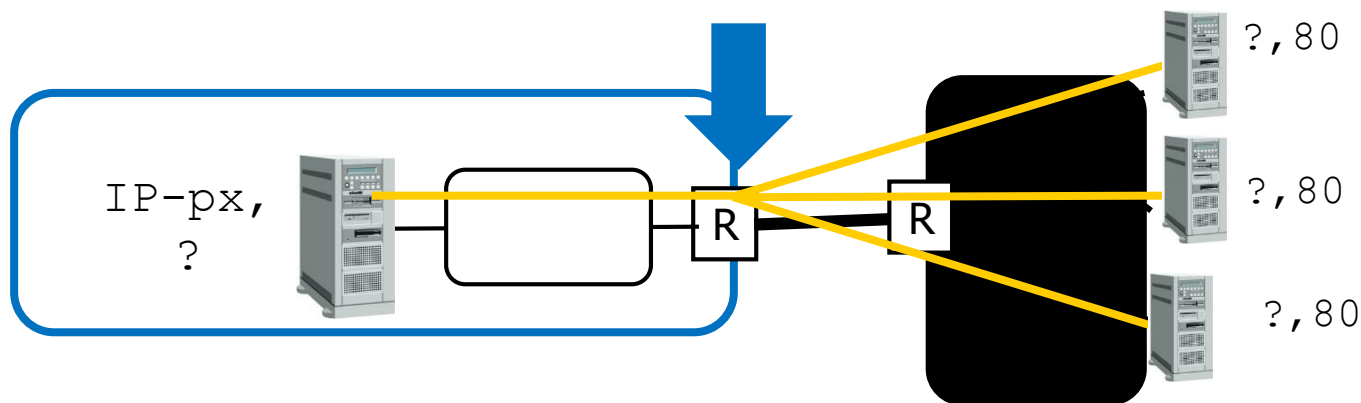
❑ Pacchetti **uscenti** permessi

- ❑ `IP-src = IP-proxy AND port-dst = 80`
- ❑ Ogni altro pacchetto uscente è proibito di default

❑ Pacchetti **entranti** permessi

- ❑ `IP-dst = IP-proxy AND port-src = 80`
- ❑ Ogni altro pacchetto entrante è proibito di default

Nostra notazione



	IP-src	IP-dst	port-SRC	port-DST
OUT	IP-px	?	?	80
IN	?	IP-px	80	?

Notazione esaustiva in quanto si derivano le regole corrispondenti **automaticamente**:

If IP-src = IP-PX AND port-dst = 80 **Then** Passa
ElseIf IP-dst = IP-PX AND port-src = 80 **Then** Passa

Bocciatura automatica



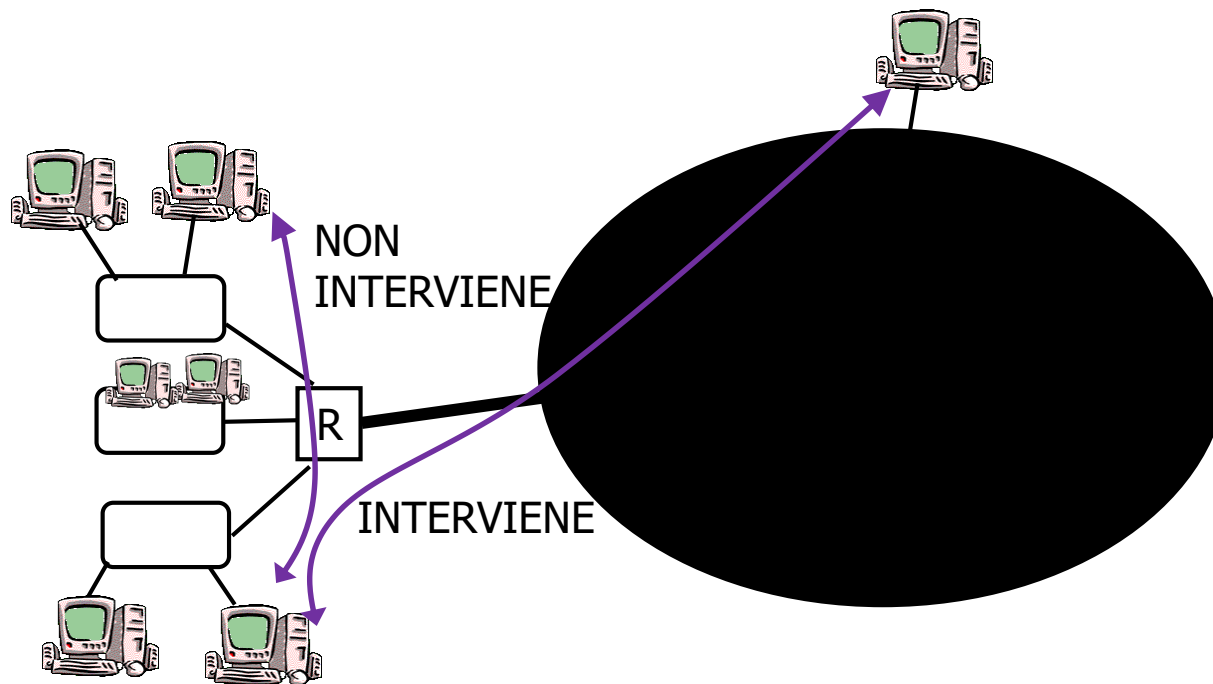
*Regole di firewall in quantità **dispari***

*Regole di firewall **monodirezionali** per ogni tipologia di traffico*

Quale protocollo può funzionare con traffico solo in un senso???

Osservazione

Firewall di frontiera analizza **solo** traffico entrante o uscente



Gergo comune 1

- ❑ blocca traffico "entrante SMTP"
- ❑ permetti traffico "uscente SMTP"
- ❑ permetti traffico "entrante DNS"
- ❑ blocca traffico "uscente DNS"
- ❑ ...

*Le connessioni sono **sempre bidirezionali!***

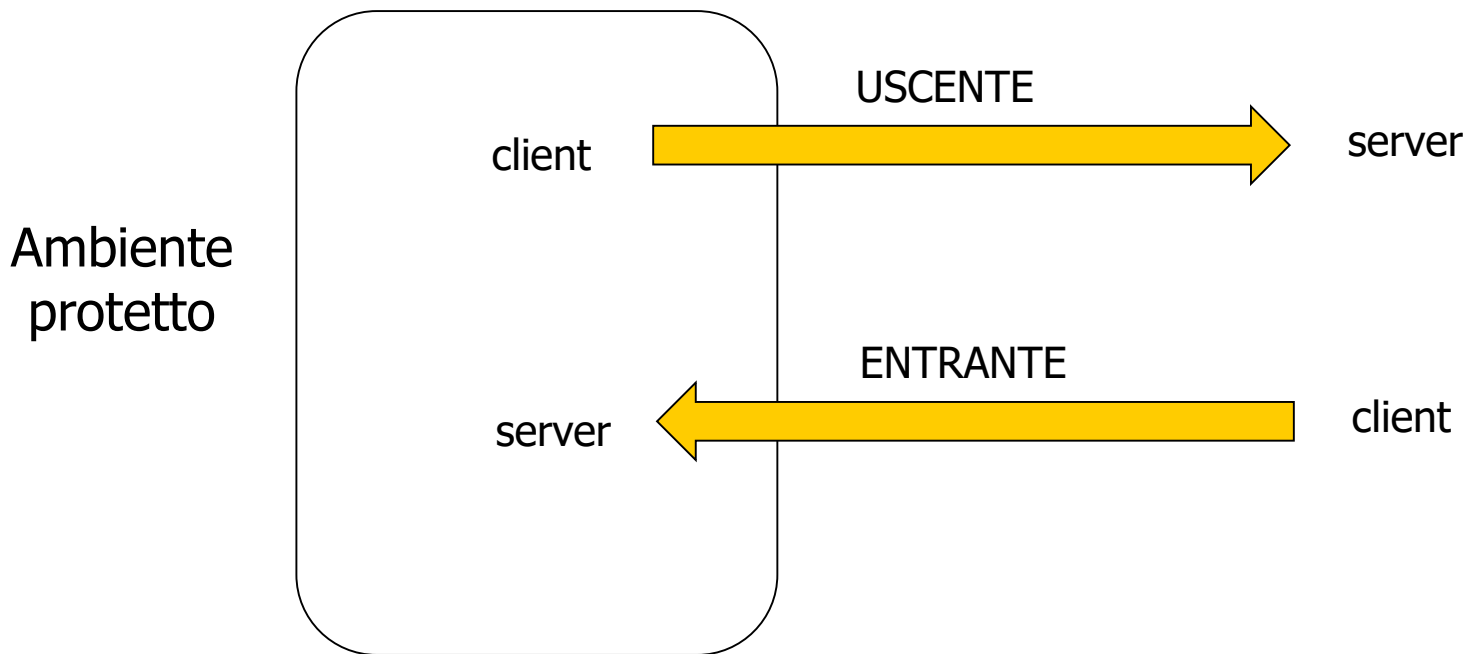
*Che senso ha bloccare in un senso
e permettere nell'altro?*

*Che significa "**entrante**" ("**uscente**")?*



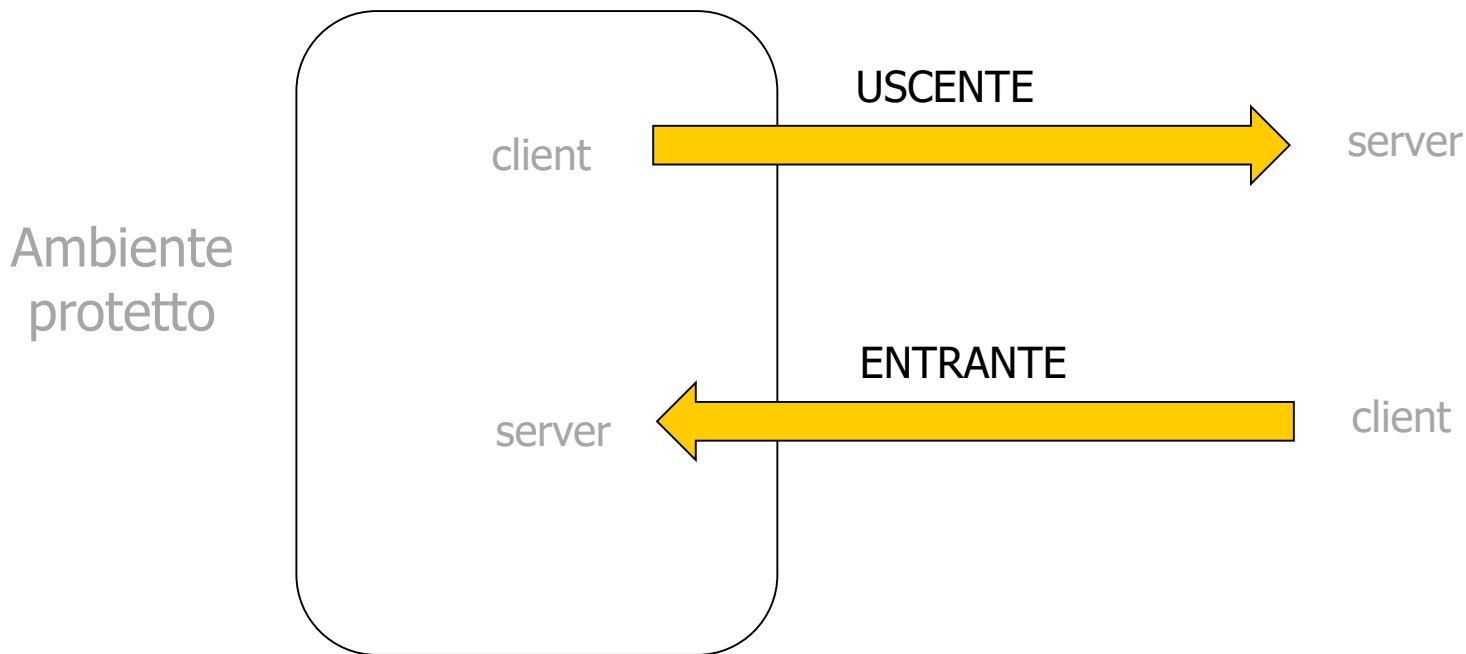
Cosa significa 1

Posizione Client/Server
rispetto all'ambiente protetto
di chi **apre** la connessione



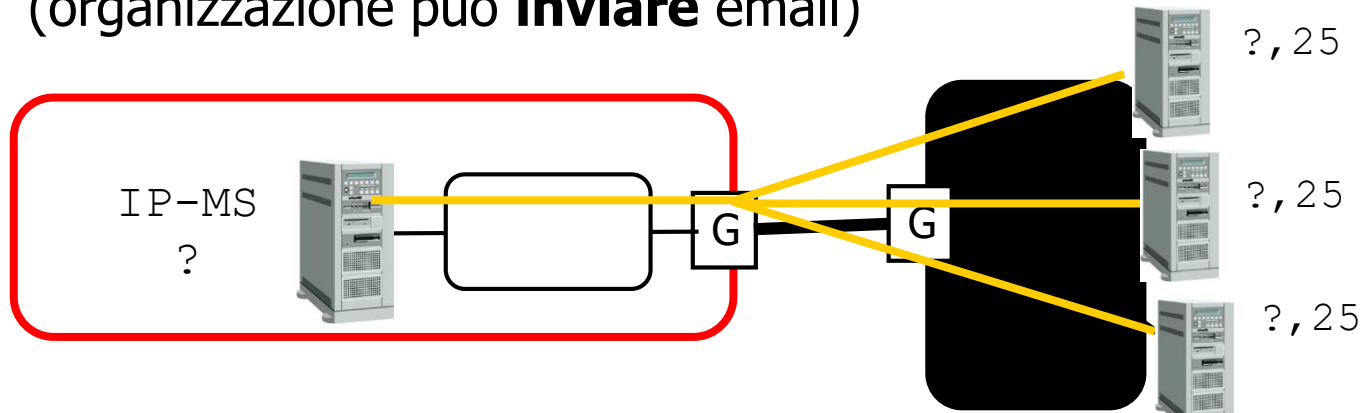
Per ricordare

"La connessione è aperta dal Client"



Esempio (I): SMTP uscente solo da MS

- Invio email **dal** mail server della organizzazione (organizzazione può **inviare** email)



	IP-src	IP-dst	port-SRC	port-DST
IN	?	IP-MS	25	?
OUT	IP-MS	?	?	25

If IP-dst = IP-MS AND port-src = 25 **Then** Passa
ElseIf IP-src = IP-MS AND port-dst = 25 **Then** Passa

Nostra notazione

- ❑ Scrivere "la tabella" non è necessario ma è utile
- ❑ Ai fini degli esami è sufficiente fornire solo "la tabella"

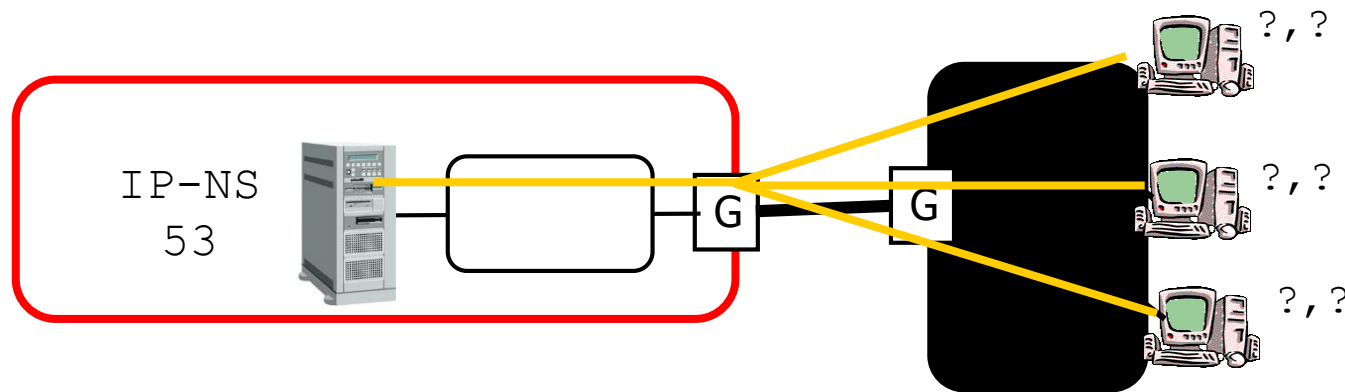
	IP-src	IP-dst	port-SRC	port-DST
IN	?	IP-MS	25	?
OUT	IP-MS	?	?	25

Passaggio meccanico

```
If IP-dst = IP-MS AND port-src = 25 Then Passa
ElseIf IP-src = IP-MS AND port-dst = 25 Then Passa
```

Esempio (II): DNS entrante solo verso NS

- Accesso dall'esterno verso il name server della organizzazione

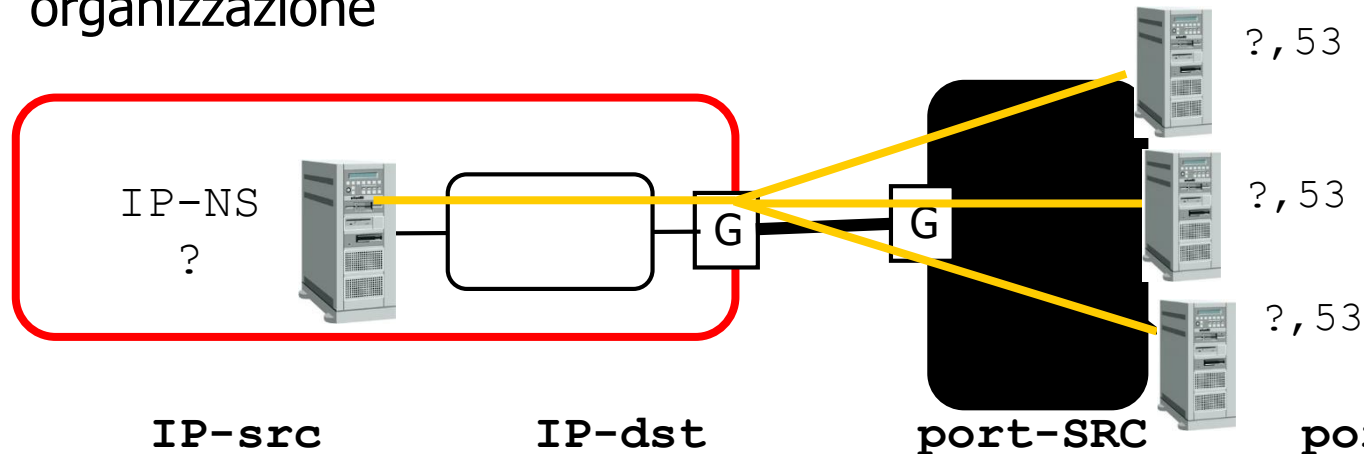


	IP-src	IP-dst	port-SRC	port-DST
IN	?	IP-NS	?	53
OUT	IP-NS	?	53	?

If IP-dst = IP-NS AND port-dst = 53 **Then** Passa
ElseIf IP-src = IP-NS AND port-src = 53 **Then** Passa

Esempio (III): DNS uscente solo da NS

- Accesso verso name server esterni da name server della organizzazione

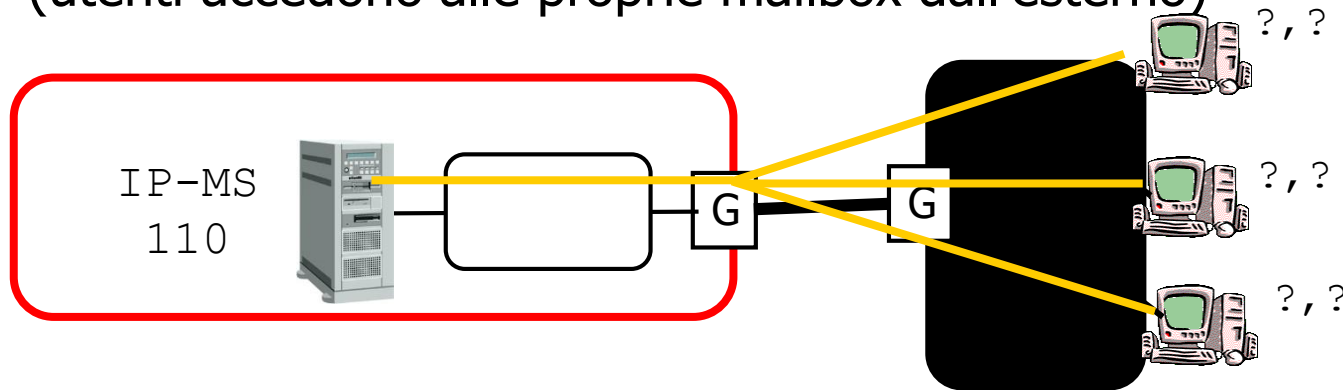


	IP-src	IP-dst	port-SRC	port-DST
IN	?	IP-NS	53	?
OUT	IP-NS	?	?	53

If IP-dst = IP-NS AND port-src = 53 **Then** Passa
ElseIf IP-src = IP-NS AND port-dst = 53 **Then** Passa

Esempio (IV): POP entrante solo verso MS

- Prelievo email **dal** mail server della organizzazione (utenti accedono alle proprie mailbox dall'esterno)



	IP-src	IP-dst	port-SRC	port-DST
IN	?	IP-MS	?	110
OUT	IP-MS	?	110	?

If IP-dst = IP-MS AND port-dst = 110 **Then** Passa
ElseIf IP-src = IP-MS AND port-src = 110 **Then** Passa

Esempio (V):

HTTP uscente solo da N1

- Accesso verso web server esterni **solo da network interna N1**

	IP-src	IP-dst	port-SRC	port-DST
OUT	netNum(N1)	?	?	80
IN	?	netNum(N1)	80	?

If IP-src $\in$ netNum(N1) AND port-dst = 80 **Then** Passa
ElseIf IP-dst $\in$ netNum(N1) AND port-src = 80 **Then** Passa

Struttura esercizi

- ❑ Input: Specifica **testuale** del traffico da permettere
- ❑ Output: Insieme regole

- ❑ Valutazione soluzione:
 - ❑ Permetto tutto Inaccettabile
 - ❑ Permetto più del necessario ("permetto troppo") Gravemente sbagliata
 - ❑ Permetto **solo lo strettamente necessario** Corretta
 - ❑ Permetto non tutto il necessario ("manca qualcosa") Sbagliata
 - ❑ Non permetto nulla Inaccettabile

- ❑ In passato assegnavo solo esercizi per firewall di frontiera
- ❑ Da pochi anni anche per i firewall su endpoint

Come si risolvono



- ❑ **Non** cercate di imparare i vari casi a **memoria**
- ❑ Troppe combinazioni possibili
 - ❑ Name server: interno organizzazione o in ISP?
 - ❑ Mail server: interno organizzazione o in ISP?

- 1. Disegnare ambiente protetto
- 2. Per ogni tipologia da permettere
 - a) Individuare posizione dei server
 - b) Disegnare connessione
 - c) Se attraversa il firewall, allora scrivere le due regole

Gergo comune 2

- ❑ blocca traffico "SMTP **di tipo client**"
- ❑ permetti traffico "SMTP **di tipo server**"
- ❑ permetti traffico "HTTP **di tipo client**"
- ❑ blocca traffico "HTTP **di tipo server**"
- ❑ ...

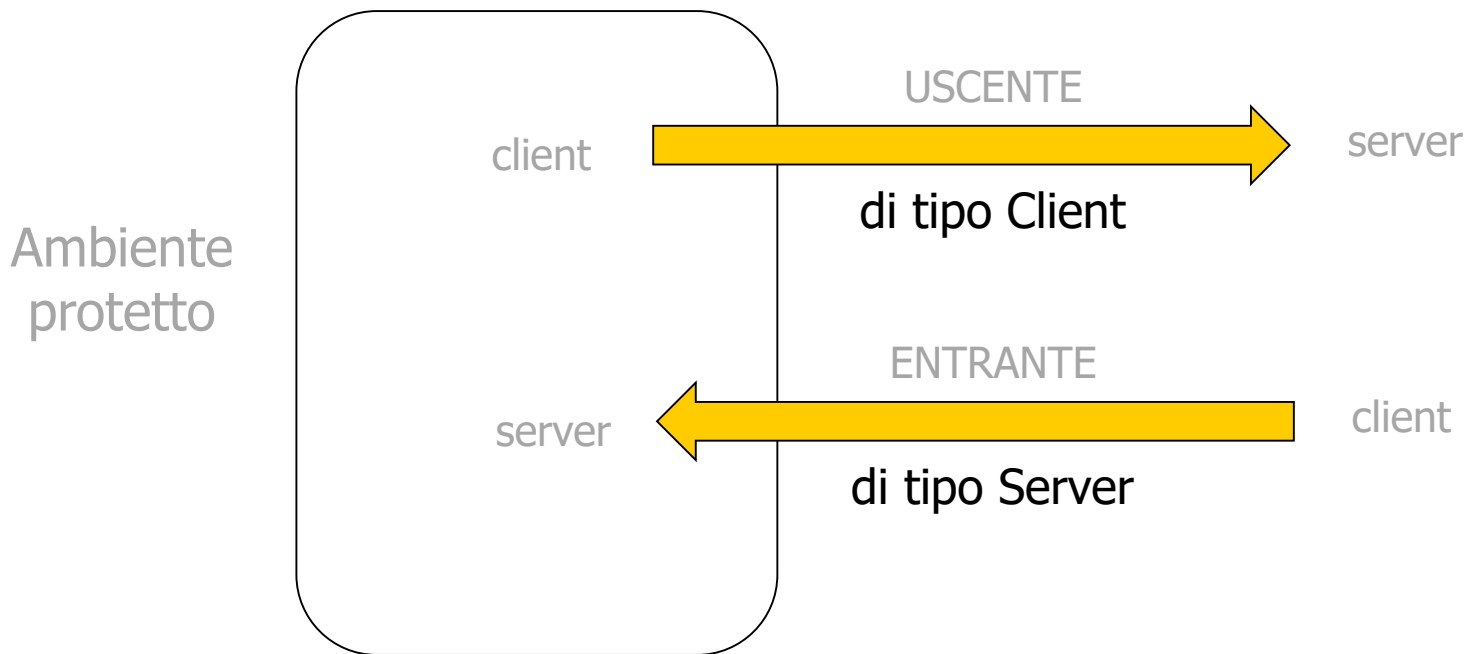
*Ogni connessione ha **sempre**
un server e un client!*

Che significa bloccare uno dei due?



Cosa significa (REMINDE)

Posizione Client / Server
rispetto all'ambiente protetto
di chi **apre** la connessione



TEST

A thick, horizontal yellow brushstroke with a textured, painterly appearance, extending across the width of the slide below the 'TEST' header.

IP - Firewall

Esempio



Firewall 1 Esercizi svolti parte 2

Firewall "reali"

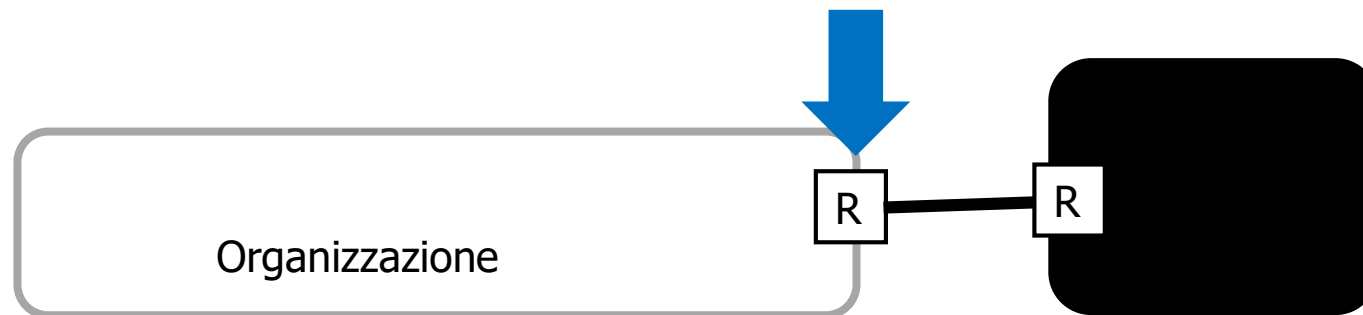


Firewall di frontiera: Il mondo dei sogni

- ❑ Esiste un elenco completo delle tipologie di traffico strettamente necessarie per tutti i nodi interni
 - ❑ Centinaia / Migliaia nodi
 - ❑ Molte sezioni / dipartimenti



- ❑ Insieme di regole strettamente necessarie facile da determinare

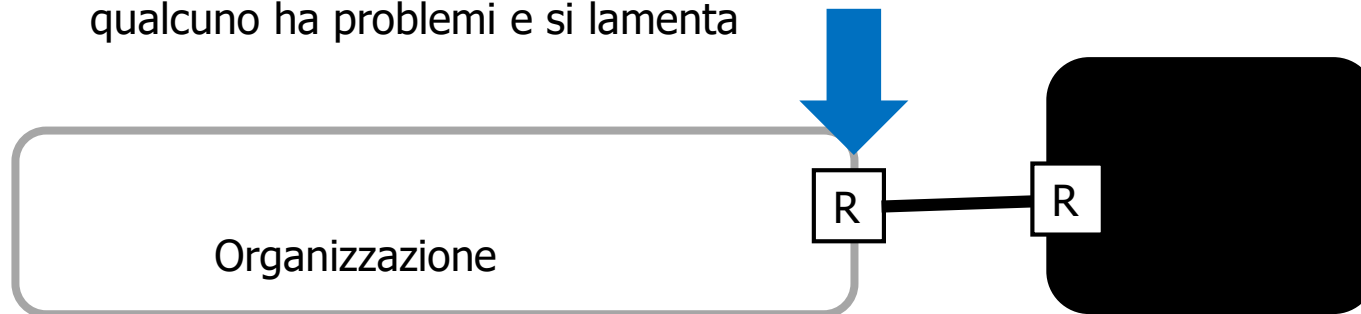


Firewall di frontiera: La realtà

- ❑ Nessuno ha idea di:
 - ❑ quanti e quali server esistano internamente
 - ❑ quanti client esistano internamente e di quali server esterni hanno necessità



- ❑ Insieme di regole **molto più permissivo** del necessario
 - ❑ Se manca qualcosa è facile accorgersene: qualcuno ha problemi e si lamenta



Windows Firewall



- ❑ **Estremamente potente: numerose** possibilità di configurazione
- ❑ Configurazione di default: permette praticamente tutto
⇒ non protegge per niente (come non averlo)
- ❑ Motivo:
 - ❑ Configurazione default permette solo insieme di traffico "tipico" X
 - ❑ Utente necessita traffico non contenuto in X
(esempio: usa un software che la Microsoft non conosce)
⇒ Non funziona
 - ❑ Utente non sa configurare il firewall
⇒ Dramma

Non vi stupite!



❑ Motivo:

- ❑ Configurazione default permette solo insieme di traffico "tipico" X
- ❑ Utente necessita traffico non contenuto in X
(esempio: usa un software che la Microsoft non conosce)

⇒ Non funziona

- ❑ Utente non sa configurare il firewall

⇒ Dramma

❑ Sicurezza e Funzionalità sono sempre in **conflitto**

❑ Quasi sempre si privilegia la Funzionalità

Interfaccia utente "reale"

- ❑ Dipende dal sistema operativo
 - ❑ Nostro formato più simile a Linux che a Windows
- ❑ Regole possono avere **molti** operandi
 - ❑ Protocollo del payload
(per noi è sempre TCP)
 - ❑ Programma a cui si applica la regola
(porte discendono implicitamente)
 - ❑ Utente del programma a cui si applica la regola
(mistero: come fa il livello IP a capire quale utente ha inviato un pacchetto?)
 - ❑ ...

Programma	Indirizzo locale	Indirizzo remoto	Porta locale	Porta remota	Protocollo	Operazione
C:\program files\cryptomator\cryptomator.exe	Qualsiasi	Qualsiasi	Qualsiasi	Qualsiasi	UDP	Consenti
C:\program files\cryptomator\cryptomator.exe	Qualsiasi	Qualsiasi	Qualsiasi	Qualsiasi	TCP	Consenti

Linux IPTables



Allow All Incoming HTTP

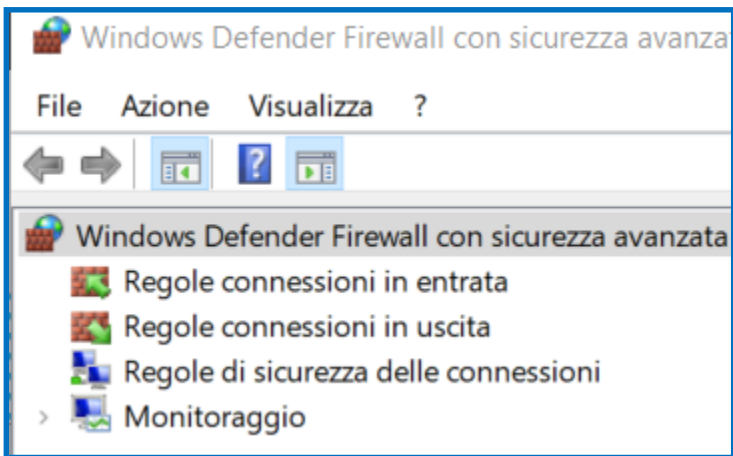
```
iptables -A INPUT -p tcp --dport 80 -m conntrack --ctstate NEW,ESTABLISHED -j ACCEPT
iptables -A OUTPUT -p tcp --sport 80 -m conntrack --ctstate ESTABLISHED -j ACCEPT
```

Allow Incoming SSH from Specific subnet

```
iptables -A INPUT -p tcp -s 192.168.240.0/24 --dport 22 -m conntrack --ctstate NEW,ESTABLISHED -j ACCEPT
iptables -A OUTPUT -p tcp --sport 22 -m conntrack --ctstate ESTABLISHED -j ACCEPT
```

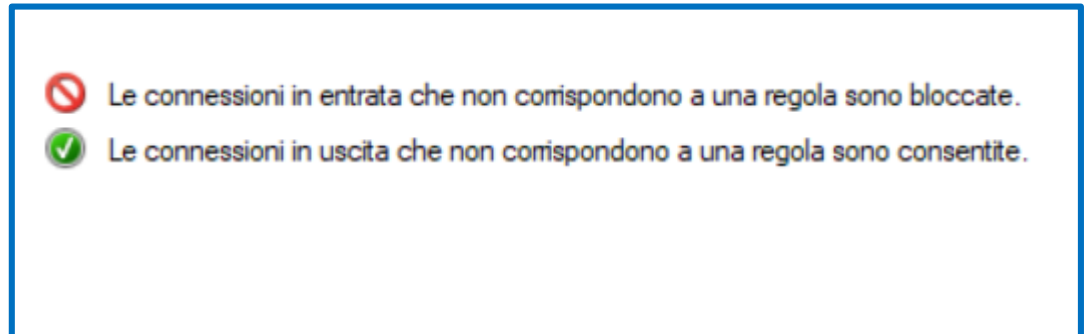
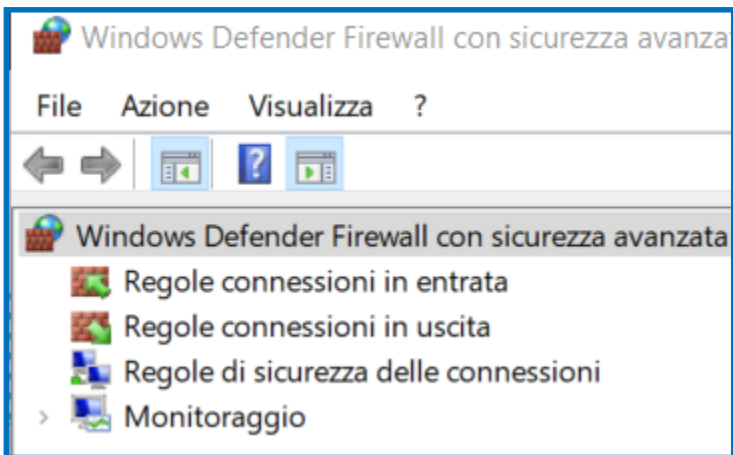
Windows (I)

□ Pannello di controllo → Windows Defender Firewall → Avanzate



Windows (II)

□ Pannello di controllo → Windows Defender Firewall → Avanzate



- **Entrata:** "tutto proibito"
 - Ma l'insieme di regole permette praticamente tutto
- **Uscita:** "tutto permesso" (!!!)

Uno dei drammi odiermi



- ❑ **Entrata:** "tutto proibito"
 - ❑ Ma l'insieme di regole permette praticamente tutto
- ❑ **Uscita:** "tutto permesso" (!!!)

- ❑ Organizzazione con centinaia di nodi Windows
- ❑ SE **1** nodo ha preso un malware
- ❑ ALLORA Malware può collegarsi con (=infettare) **tutti** gli altri nodi
- ❑ E' così che si bloccano completamente le organizzazioni (ovviamente semplifico molto)
- ❑ Firewall di frontiera oggi è pochissimo utile